

Instalación, Análisis y Explotación de Entornos Vulnerables Usando Kali Linux, Docker y DVWA

El estudio de la ciberseguridad ofensiva exige ambientes seguros donde el analista pueda aplicar técnicas reales sin comprometer sistemas de producción. Para ello se emplean entornos vulnerables deliberadamente expuestos, como DVWA o máquinas de Vulnhub, y herramientas como Docker, Nmap, Metasploit o sqlmap. Esta lectura profundiza en cada concepto, comando y herramienta involucrada en la preparación, análisis y explotación de estos entornos.

Para comenzar, se requiere una máquina preparada como Kali Linux, la cual contiene utilidades avanzadas para tareas ofensivas. Un paso fundamental es instalar **Docker**, una tecnología de contenedores que permite desplegar aplicaciones de forma ligera y aislada. Con Docker, por ejemplo, es posible ejecutar una instancia de DVWA (Damn Vulnerable Web Application), una aplicación web diseñada para ser vulnerable.

La instalación de Docker se inicia con `sudo apt update`, que sincroniza la lista de paquetes disponibles, y `sudo apt install docker.io -y`, que instala el paquete `docker.io`. Luego, se activa el servicio con `sudo systemctl start docker` y se configura para que se inicie automáticamente con `sudo systemctl enable docker`. El estado se comprueba con `sudo systemctl status docker`. Todos estos comandos pertenecen al sistema de gestión de servicios `systemd` y son esenciales para asegurar que Docker se ejecute correctamente en segundo plano.

Una vez Docker está activo, ejecutar un contenedor de DVWA se realiza mediante el comando:

```
sudo docker run --rm -it -d -p 80:80 vulnerables/web-dvwa
```

Este comando lanza una instancia interactiva (`-it`) y en segundo plano (`-d`) del contenedor `vulnerables/web-dvwa`, mapeando el puerto 80 del contenedor al puerto 80 de la máquina local (`-p 80:80`). El modificador `--rm` elimina el contenedor una vez se detiene. Con este contenedor en ejecución, se puede acceder a la aplicación desde el navegador a través de `http://localhost`, y autenticarse con credenciales por defecto como `admin/password`.

Una vez dentro, DVWA permite explorar vulnerabilidades comunes como **inyecciones SQL**, **XSS**, **file upload**, y más. Para pruebas iniciales, se puede cambiar el nivel de seguridad a "low" desde la interfaz web, lo que facilita la explotación básica.

La inyección SQL es una técnica que consiste en insertar código SQL malicioso en campos de entrada de usuario. Por ejemplo, al colocar `' OR '1'='1` en un campo que consulta la base de datos sin sanitización, se altera la lógica del SQL interno y se obtienen múltiples

resultados, demostrando que el campo es vulnerable. Esta prueba es clásica para verificar si la aplicación está expuesta a ataques de tipo SQLi (SQL Injection).

Más allá de DVWA, se puede trabajar con máquinas completas vulnerables, como las que ofrece Vulnhub. Estas son imágenes de sistemas operativos configurados con vulnerabilidades intencionadas. Para su uso, primero se descargan e importan en VirtualBox. Para que la máquina Kali Linux y la VM vulnerable puedan comunicarse, ambas deben estar en la misma red virtual, configuradas como "red interna" o "solo anfitrión".

Una vez iniciadas ambas máquinas, se verifica la conectividad usando el comando `ping <IP>` desde Kali hacia la máquina vulnerable. El siguiente paso es identificar los servicios activos y sus versiones con **Nmap**, un escáner de redes potente que permite descubrir puertos abiertos, servicios y sistemas operativos. El comando:

```
nmap -sS -sV -O <IP objetivo>
```

realiza un escaneo TCP SYN (`-sS`), detecta versiones de los servicios (`-sV`) y trata de identificar el sistema operativo (`-O`). El resultado ofrece información crucial como puertos abiertos (por ejemplo, 22 para SSH, 80 para HTTP), el software detrás (Apache, OpenSSH, etc.) y sus versiones.

Con los datos recolectados, se procede al análisis de vulnerabilidades. Una buena práctica consiste en buscar vulnerabilidades conocidas (CVEs) usando la versión exacta del software detectado. Esto se puede realizar en sitios como cvedetails.com o exploit-db.com. El objetivo es identificar si esa versión del servicio es explotable, por ejemplo, por ejecución remota de código o escalada de privilegios.

Si se encuentra una vulnerabilidad conocida, el siguiente paso es simular su explotación. Para ello se utilizan herramientas ofensivas. **Metasploit Framework** es una plataforma avanzada que automatiza gran parte del proceso de explotación. Permite buscar exploits mediante `search`, configurar el objetivo con `set`, y lanzar ataques con `exploit`.

Otra herramienta potente es **sqlmap**, usada específicamente para automatizar ataques de inyección SQL. Basta con especificar una URL vulnerable y sqlmap intentará detectar y explotar la vulnerabilidad:

```
sqlmap -u "http://<IP>/vulnerable.php?id=1" --dbs
```

Este comando intenta obtener las bases de datos disponibles mediante inyección. También puede enumerar tablas, usuarios o incluso obtener acceso al sistema operativo.

Hydra es una herramienta de fuerza bruta para servicios como FTP, SSH o HTTP. Permite probar múltiples combinaciones de usuario y contraseña para obtener acceso. Por ejemplo:

```
hydra -l admin -P rockyou.txt ssh://<IP>
```

Este comando intenta ingresar al servicio SSH usando el usuario **admin** y el diccionario **rockyou.txt**.

Netcat, por otro lado, es una utilidad de red para leer o escribir datos a través de conexiones TCP/UDP. Puede usarse tanto para conectarse a servicios abiertos como para establecer un shell reverso:

```
nc -lvp 4444
```

Escucha conexiones entrantes por el puerto 4444, útil cuando una máquina comprometida envía una shell al atacante.

Una vez demostrada la vulnerabilidad, se deben proponer medidas de remediación. Por ejemplo, si la explotación fue vía SQLi, se debe implementar validación y sanitización de entradas, uso de consultas preparadas (prepared statements) y políticas de mínimo privilegio en la base de datos. La documentación del proceso también es clave: registrar IPs, puertos, comandos y resultados permite trazar el ataque y construir un informe profesional.

En resumen, los conceptos clave tratados abarcan desde la instalación de contenedores seguros con Docker hasta la detección y explotación de vulnerabilidades reales con herramientas especializadas. El dominio de estos elementos prepara al estudiante para auditorías controladas y éticas, respetando el principio de “no dañar” y promoviendo el aprendizaje práctico y responsable.